

Information security Management System (ISMS)

SECURITY ATTACK: WANNACRY – NHS RANSOMWARE
ATTACK

KARANVEER SINGH MALHI ~~Nottingham Trent University~~

Contents

1 Introduction to WannaCry Ransomware Attack:	3
1.1 Attack introduction (WannaCry):	3
1.3 Type of Attack:	3
1.2 Key Details:	3
1.4 Organisational Impact:	3
2 Analysis of the WannaCry Issue	4
2.1 Cause of WannaCry 4 Stages:	4
2.2 Threat Vectors	5
2.3 Key Assets Involved:	6
2.4 Short-Term Impacts:	7
3 Scope:	8
4 Asset:	9
4.1 Asset Register: Asset register headers:	9
4.2 Threat Actor Table:	24
5 Risk Register:	31
5.1 Controls:	48
6 Evaluation and Discussion:	53
Bibliography:	55

1 Introduction to WannaCry Ransomware Attack:

1.1 Attack introduction (WannaCry):

WannaCry was a ransomware attack that occurred on May 12th, 2017 (Chen, 2017). This attack affected numerous companies across the globe, causing damages to over 156 countries (Anon., n.d.) and more than 200,000 devices worldwide (Anon., n.d.). This attack was a successful heist as the attackers were able to exploit vulnerabilities within devices, the majority of which had outdated operating systems (previous versions of Microsoft) and old-generation devices that contained many bugs and weak spots, which made the system very prone to attacks. When the attackers successfully installed the ransomware malware onto users' devices, the malware encrypted all files within the victims' systems and then demanded a bitcoin payment ranging from \$300 to \$600 to decrypt the data back to its original state (Anon., n.d.).

1.3 Type of Attack:

WannaCry was a malicious malware known as ransomware. This type of malware is used to encrypt a victim's data, preventing any access to the files. If an attacker is successful with implanting the malware, the hacker will demand the victim to pay a ransom for the decryption of the files. The payment they request is usually crypto, as crypto is a nontrackable currency that is hidden from investigators (Gazet, 2024).

1.2 Key Details:

The WannaCry attack spread rapidly across networks. The attack had similar features as a worm attack in the way it multiplied (Anon., n.d.). The attack was successful at spreading due to a flaw within the Microsoft Server Message Block protocol (Aljaidi, 2024), more specifically the EternalBlue exploit. This exploit was developed by the National Security Agency (Tarah Wheeler & John, 2024) and was leaked by a hacking organisation known as Shadow Brokers (Aljaidi, 2024). Even though Microsoft developed a patch for this security issue 2 months before the attack, many organisations failed to update systems, which made them victims of the WannaCry attack.

1.4 Organisational Impact:

The WannaCry attack had a significant long-term impact on many companies. An example company is the NHS where the attack caused significant damages due to cancellations of major health care services. Which inevitably caused severe disruption in patients' health, financial services, telecommunications, and transport

The failure to implement patch management of identified vulnerabilities was not the sole reasoning behind this issue as this attack reflected on organisations shortcomings:

Organisation negligence:

Major fault with many companies was that updates were often neglected due to both the use of outdated equipment and the lack of proactive security. Scheduled upgrades were often postponed due to conflicting business objectives or simply neglected (Anon., 2024).

Awareness Issues:

Due to a lack of understanding the severity of vulnerabilities and the possible effect of cyberattacks, many organisations overestimated the danger that are associated with delayed patching, this knowledge gap spanned across many layers of the organisation. (Anon., 2024)

Resource Constraints:

Allocation of resources for timely IT maintenance and cybersecurity enhancements was difficult for many smaller organisations or who had a limited budget. This resulted in insufficient staff or old technology and software which was unable to roll out quick patches. (Anon., 2024)

2 Analysis of the WannaCry Issue

2.1 Cause of WannaCry 4 Stages:

1. Survey Stage:

The WannaCry attack was caused due to a vulnerability found within older version of Windows more specifically, the Server Message Block protocol, which was exploited by making use of a known tool known as EternalBlue, which was developed by NSA. Since the NSA never disclosed this information, it was kept unpatched by the developers for the next Windows update, making systems with older versions of Windows to be vulnerable to attacks. Unfortunately, this information (EternalBlue) was leaked to the public by an organisation known as shadow brokers.

In the case of the ransomware attack, it was able to scan devices with an open SMB port, only affecting devices that weren't updated to the latest version, which resulted in unpatched devices being exploited by the ransomware. (Liu, 2024)

2. Delivery Stage

WannaCry spread to devices rapidly with its worm like behaviour combined with the EternalBlue exploit. When the ransomware enters unpatched device, it scans the local network for devices that contain the same vulnerability. Unlike other ransomware, WannaCry spread to devices without any user interaction. (Maxat Akbanov, 2024)

When WannaCry identifies devices that contain the same vulnerability, it uses EternalBlue to gain unauthorised access, once given access, it installs the ransomware and encrypts all files on the devices. This issue was worsened by the widespread use of unpatched devices especially within companies that contained outdated devices. This attack highlights the risks posed by unpatched vulnerabilities in commonly used software. (Maxat Akbanov, 2024)

3. Breach Stage:

Once WannaCry infiltrated systems it made use of encryption to lock files from victims of the attack, which makes the files inaccessible to users unless they have access to the decryption key. To obtain this key attacker's demand victims a ransom payment. If companies are unable to meet the attackers demands, it can result in the loss of data. (Maxat Akbanov, 2024)

The encryption process was executed with precision which focused on important files and directories that are essential for an organisation's operation. WannaCry also tried to block system restore points which made it more difficult for companies to recover systems using their security plans forcing companies into paying the ransom.

4. Affected Stage

For many companies it caused significant disruptions. In the NHS case since data was blocked it forced many important surgeries to be cancelled, delayed appointments and systems had to switch to manual processes. Causing major issues like financial losses estimated around millions. (Anon., 2024)

However, the attacks implications went beyond disruptions. It highlighted the weaknesses within global cybersecurity practices, like how the NHS relied upon outdated software and hardware and the failure to apply important patches.

In the end WannaCry highlighted to the public the importance of implementing simple cybersecurity practices like if organisations where not to implement scheduled patch management it could create significant disasters like the WannaCry attack. the attack highlights the need for security measures (regular patch management, robust network segmentation, scheduled secure data backups), to mitigate the risk of similar attacks in the future.

2.2 Threat Vectors

1. Exploitation of EternalBlue:

The primary way in which WannaCry spread was the exploitation of EternalBlue more specifically a vulnerability found within the Microsoft SMB protocol. An exploitation which was originally identified by the NSA which then was leaked by a hacking group (shadow brokers). (Adam B. Turner, 2024)

2. Worm Features:

WannaCry is a unique type of ransomware as traditional ransoms usually require a user's interaction (downloading malicious documents), WannaCry had the features of a worm which allowed it to propagate automatically across networks. (Adam B. Turner, 2024)

3. Unpatched software:

The attack only affected systems which contained outdated OS (Windows XP, Windows Vista, Windows 7, and Windows Server 2003) this outdated software lacked the SMB vulnerability patch which was necessary for preventing the attack. (Milan Tuba, 2024)

4. Lateral Movement via Network Shares:

When WannaCry infiltrates a network, it took advantage of weaknesses within SMB protocol to spread across shared resources, affecting multiple machines connected to the same system. The lack of network segmentation allowed the malware to spread with minimal resistance leading to significant damages. (Aljaidi, 2024)

2.3 Key Assets Involved:

1. **Data Assets:** This attack encrypted many pieces of sensitive data from victims, including patient health information and business information, which caused significant operational challenges like many appointments being cancelled because they had no access to details like appointment dates, making the issue more complicated to deal with.
 2. **Reputation of Companies:** Due to a preventable attack, many companies lost a lot of financial resources and lost public trust. This raised serious concerns about data security and compliance with regulations, which negatively impacted their reputation.
 3. **Financial Resources:** Due to recovery expenses, ransom payments, and lost income exceeding billions worldwide, many organisations had to redirect funding from other essential areas to manage the aftermath from the assault.
 4. **Human Resources:** Workers' capacity to carry out necessary duties was severely limited. Staff members experienced more stress and anxiety because of the incident, underscoring the necessity of crisis communication and crisis management training.
 5. **Technology infrastructure:** as soon as companies were attacked many of the devices on the network were compromised, which resulted in devices to be unactive. This severely affected many people such as patients at hospitals as this caused delays to emergency responses and appointments.
-

2.4 Short-Term Impacts:

This section explains the many different issues that occurred after the ransomware attack what overall affects it had on companies across the globe and especially the health care Industry (NHS).

- Many companies were fortunate to have backup of their data, allowing them to regain access to the lost data. However, majority of organisations had poor security measures which led to serious risks and disruptions to occur. One of these issues was the risk of permanently losing sensitive data. This loss causes a severe negative effect on the reputation of the organisation, causing loss of customer trust and financial loss. (Aljaidi, 2024)
 - Many facilities were forced to cancel many important appointments such as surgeries, delayed treatments all of which was the cause of inability to access patient records (causing health risks). This event highlighted the urgent need for strong security measures to protect patients' safety and ensure continuity of care. (Anon., 2024)
 - Company Reputation: since the cyber-attack was successful at taking advantage of the poor security infrastructure it created a large sum of negativity towards the reputation of the company as customers viewed them less trustworthy, many of these clients' sensitive data was leaked showing that these companies were not capable of safeguarding data. All of which made their relationship with customers more scares as clients and investors questioned the companies' ability to secure data effectively. (Anon., 2024)
 - Financial Loss: Ransom payments, recovering compromised systems and last-minute implementation of cyber security measures. Due to the companies having to force lockdown to recover from the attack many lost significant amounts of revenue as all possible sales were closed at the time. Additionally, for companies that lost customer trust, there was a risk of reduced sales and client retention in the short term, compounding the overall financial impact of the attack. (Aljaidi, 2024)
 - Disruption: with the attack affecting many organisations it caused a significant setback in the production which resulted in loss profit and made many companies to fall behind business requirements as in this period staff was dedicated to preventing the spread of the attack from reaching vital points of their systems overall putting a strain on companies' staff. (S. Ghafur, 2024)
-

3 Scope:

This ISMS security plan will be focused upon protecting Lister Hospital (Anon., n.d.), a healthcare sector within the East and North Hertfordshire NHS Trust that was affected by the WannaCry attack. Lister Hospital plays a crucial role in providing major healthcare services (surgeries, emergency services, and patient treatment to a large quantity of patients). Because of the cyberattack, it highlighted vulnerabilities within the hospital's IT systems, which resulted in severe disruptions and damages to important medical services due to the use of outdated software and inadequate cybersecurity measures.

This ISMS will be designed to secure all IT assets; this can include the following (operational networks, supporting infrastructure, patient data, and clinical applications). This ISMS will also address the key mitigation tactics (data encryption, access control, scheduled patch management, and cybersecurity training programs). By focusing on these areas, the plan can successfully help prevent any future attacks.

The ISMS will be based upon the ISO 27001 standards (Brenner, 2007) and integrated with the NHS digital cybersecurity policy (Anon., 2018), addressing global compliance requirements while being tailored to specific problems of the healthcare sector. It includes practical steps that will address the vulnerabilities that were identified during the ransomware attack and build a strong, lasting security structure. This strategy will prioritise the protection of both technology and human elements to safeguard sensitive patient data and critical operational systems.

The aim of the ISMS is to develop a strong, responsive security infrastructure that can help detect and prevent future cyberattacks, protecting patients' sensitive information, and ensuring that the delivery of essential healthcare services runs smoothly without any disruptions.

4 Asset:

4.1 Asset Register:

Asset register headers:

Columns (likelihood, impact and value) are measured using the following measurements (Low, Medium, High, Very High)

- **ID** – unique number identifier
- **Asset** – something which holds value for the NHS
- **Likelihood of Damage/Loss** – The chances of a risk occurring.
- **Impact of damage/loss** – the consequence level if risk where to occur
- **Value** – the assets importance
- **Owner** – individuals that are responsible for the asset
- **Comments** – any notes about the asset

ID	Process/ Asset Class	Asset	Likelihood of Damage/ Loss	Impact of Damage/Loss	Value	Owner	Comments
1	Data	Electronic Medical Records (EMR)	Medium	Very High - Interruption of patient care. - Loss of trust from patients. - Potential legal actions against company. - Financial and reputational repercussions.	Reputation: Very High Operational Impact: Very High Regulatory Fines: High	- Medical records staff/manager - Medical summariser	- Essential for managing patient data, secured through encryption, access controls and routine audits. - EMR must comply with the NHS cybersecurity Framework, GDPR and data protection act.
2		Audit Trail	Low	Medium - Losing data can harm forensic analysis, making it harder to hold people accountable, and affect compliance with regulations.	Reputation: Medium Regulatory fines: Medium Operational impact: Medium	- Data Protection Officer - IT Security Manager/staff	- Essential for tracking the access to systems. - Everything is managed according to NHS IT security policies.
3		Medical Imaging Data (x-ray and MRI scans and other health images)	Medium	Very High - If images are compromised, delayed or incorrect it can cause incorrect diagnoses which can negatively affect the health of patients. - Legal liabilities - Loss of trust	Reputation, Legal liabilities and Operational Impact: Very High	- Radiology Manager - Clinical radiology - Data Protection Officer	- Important diagnostic data (MRI, x-ray, etc). - It must follow strict cybersecurity standards and the data protection regulations (UK data protection act and GDPR)
4		sensitive data of (patient, staff, organisation)	Medium	Very High - Breach of public data can result to identity theft. - Loss of public trust. - Reputation damage. - Legal repercussions.	Reputation: Very High Operational Impact: High Impact: High	- Data Protection Officer - Caldicott Guardian register	This data contains identifiable information which would require both strong encryption and strict access. Managed in accordance with NHS cybersecurity guidelines and regulatory requirements.

						- Information Governance Manager	
5		Patient/Staff Identifiable Information	Medium	High - Identity theft of sensitive patient information. - Legal repercussions for violating privacy laws. - Significant loss of public trust in healthcare services.	Reputation: Very High Regulatory fines: High	- Data Protection Officer - Caldicott Guardian	- This information is unique to each patient/staff which makes it easier to identify them. - Data must be protected. Enforce data protection standards, GDPR and UK data protection act.
6		Prescription Records	Medium	Very High - If prescription records are inaccessible or inaccurate it can result into medication errors which can impact a patients' life.	Reputation: High Operational impact: High	- Chief Pharmacist - Pharmacy Technician - Data Protection Officer	- This information can contain prescribed medication, dosage amount and treatment plans. - regular updates and secure access are crucial to maintaining accuracy.
7		Administrative records	Low	High - Problems with regulations can arise from not handling administrative data correctly. - Delay in operations	Reputation: Medium Regulatory fines: Medium Operational impact: Medium	- Practice Manager - Health Records Manager	Includes information (payroll, record of members, staff timetable, etc). Securely stored following NHS cybersecurity standards.
8		Appointment Scheduling Data	High	High - Loss of appointment data can disrupt the patients care delivery, which can lead to delays in treatment and potential negative health outcomes. - Damage to the organisation's reputation, resulting in decreased patient	Operational impact: High Reputation: High	- appointment coordinators - booking managers - support managers	- Stores information of patient's appointment, includes: (dates, times, healthcare providers, and appointment statuses) - Data should be backed up on a regular basis to prevent data loss and is accessed exclusively through secure scheduling software. Compliance with NHS

				trust and potential loss of business.			security and data protection protocols is an essential.
9		Research Data (Medical Research)	Low	Very High - Lossing Research can result in NHS to be set back on possible world breaking medicines, surgeries and many other procedures.	Reputation: Very High Operational impact: High	- Research Data Manager - Data Protection Officer - Clinical Scientist	Research data must be safeguarded against cyber spying. And the security measures are aligned with NHS regulatory and cybersecurity guidelines.
10		Clinical Decision Support Systems	Medium	Very High - Inaccurate decision can lead to incorrect diagnoses or incorrect treatments which can pose a harm to the patients' health. - This can cause the loss of trust between both healthcare providers and patients - Errors can cause the quality of patient treatment to be less affective in what the patient really requires which can result in their health to decline	Patient Safety: Very High Trust: High	- Chief Clinical Information Officer - Clinical Informatics Lead	- Assists healthcare providers in making decisions. - Systems require frequent updates with the latest guidelines to ensure compliance and best practices ensures high-level data protection to safeguard sensitive information. And must also follow the clinical safety regulations.
11		Telehealth Data	Medium	High - Breaches could cause the theft of sensitive information. - This can disrupt remote care services, which can affect the operations of timely medical attention.	Trust: High Operational Impact: Medium	- Telehealth Coordinator - Data Protection Officer	- Contains data from health consultations which is done using online meetings. - To keep data secure implement, encrypt communication channels to maintain data integrity and confidentiality. The security must

							also meet GDPR and NHS cybersecurity guidelines.
12		Patient Feedback and Survey Data	Medium	Medium - Loss of data can impact service improvements and weaken efforts to improve patients' experience.	Patient Trust: Medium Operational Impact: Low	- Patient Experience Manager - Health Informatics Manager	- patient feedback contains the experiences of services provided. (contains required improvements) -To keep feedback secure, implement: (anonymisation, good data management practices, staff training and encryption practices) applied according to GDPR standards can make a major security difference.
13	Hardware	IT Equipment (including computers, printers, etc)	Medium	Very High - Having any damages to devices or loss of equipment can cause significant disruption to services if equipment is required causing downtime and can lead to data loss.	Operational Impact: Very High Reputation: Very High	- IT Asset Manager - IT Services Manager	- IT equipment (includes hardware devices like computers, network devices, servers) all of which are necessary for day-to-day company operations. - Ensuring physical security, maintenance, upgrading and effective patch management according to NHS cybersecurity protocols is crucial for these devices to function.

14		Backup Systems (cloud & physical)	Low	Very High - If backups are lost/damaged it can result in permanent data loss. - Which makes it difficult to recover data if cyber-attacks were to occur (i.e. Ransomware)	Operational impact: Very High Reputation: High	- IT Infrastructure Manager - Data Protection Officer	- Having backups are crucial to companies as they can allow quick recovery of systems if endangered, which is why it's important to have regular checkups and keep them secure with encryption. - Companies should have 2 types of backups (physical which is on site and a cloud backup which can be accessed outside of company)
15		Network Switches/ Routers	Medium	Very High - Failure exposes systems to unauthorised access, increasing the risk of data breaches. - Potential compromise of sensitive information and critical infrastructure.	Operational impact: High Reputation: Medium	- network manager - IT Security Manager	- Key network devices require regular firmware updates. Configured according to NHS cybersecurity policies to keep everything safe from potential vulnerabilities.

16		Uninterruptible Power Supplies	Low	High - Power outages can cause systems to go offline which can result in losing data and interrupting important healthcare services, which can all users within the hospital.	Operational impact: High	- Facilities Manager - IT Infrastructure Manager	- The supply provides continuous power, - Requires frequent maintenance to guarantee that it operates in compliance with NHS operational requirements.
17		Medical Imaging equipment	Low	Very High - Can seriously affect diagnosis and patients' treatments. - Reliable imaging is vital for patients to receive the necessary care.	Patient Care: Very High Operational Impact: Very High	- Imaging Equipment and Radiation Protection Manager - Clinical Engineer	- Equipment x-ray, MRI scanners, equipment which can diagnose patients' health. - Important to regularly maintain and calibrate equipment. ensures that equipment functions properly. - Must follow NHS imaging, cybersecurity and maintenance guidelines.

18		Telehealth equipment	Medium	High - Loss of medical imaging equipment could significantly hinder remote consultations and patient care. This can create barriers for healthcare providers in delivering timely and effective treatment.	Patient Access: High Operational Impact: Medium	- Telehealth Equipment Specialist - Clinical Engineer	- Equipment which provides telehealth consultation, equipment: (microphones, cameras and remote monitoring devices). - Regularly maintained helps ensure that equipment has the necessary updates for equipment security and that it works effectively.
19		Medical monitoring equipment	Low	Very High - Could affect patient safety during critical conditions which could be life threatening if patients don't receive the required treatment.	Patient Safety: Very High Operational Impact: High	- Clinical Engineer - Medical Equipment Manager	- These devices help monitor a patient's health (blood pressure monitors, pulse oximeters). - requires real-time monitoring, and regular maintenance and strict security measures - Crucial to ensure that the equipment is functioning correctly and providing accurate results.
20		Diagnostic equipment	Medium	High - Equipment failure or damaged impacts patient diagnosis. This can lead to delays in identifying health issues, which may affect treatments and overall patient care.	Diagnostic Accuracy: High Operational Impact: High	- Medical Devices Manager - Clinical Engineer	- Medical devices which help in diagnosing diseases or health issues for instance blood analysers. - Secured and routinely maintained to ensure availability and in line with NHS regulatory and cybersecurity standards. This practice is vital for minimising downtime and ensuring that healthcare services can be delivered effectively when needed.

21		Emergency Equipment	Medium	Very High - lack of availability could endanger patient lives in emergencies. It's critical to have systems in place that always guarantee access to necessary resources to protect patient safety.	Patient Safety, Critical Emergency, Readiness: High	- Emergency Preparedness Officer - Clinical technician	Important to keep everything in ready condition with regular check-ups, making sure that equipment works as it is supposed to. That way, if an emergency were to occur, equipment is ready when needed the most this could save patients' lives (e.g. ventilators, first aid equipment). This must be done in accordance with NHS emergency and cybersecurity guidelines.
22		Transport equipment	Medium	High - If transport is damaged, it can pose a threat on a patient's life, as it could hinder their movement, which could lead to various issues like not being able to transport them to a safe location or delay them from getting to important emergencies, which could endanger their health.	Operational Impact: High Patient Care: Medium	- Patient Transport Service (PTS) call handler	Transport equipment includes wheelchairs, transportation beds, and any other equipment that provides movement to patients. To combat these issues, having regular check-ups and maintenance of equipment ensures safe patient transport in compliance with NHS transport and safety standards.
23	Service	Emergency Transport (Ambulances)	Medium	Very High - Any issues with emergency transport can result endangerment of patient's life which can possibly result in life-or-death situation.	Operational Impact: Very High Reputation: High	- Transport Services Manager	Vehicle communication and navigation systems need to be secure; this can be achieved by encryption and regular patches as per NHS emergency protocols and cybersecurity standards.

24		IT support	Medium	High - Can lead to the loss of IT support, which would lead to issues like system downtime if errors occurred within systems, decrease of productivity, raise security issues such as possible cyber-attacks, all of which reduces the efficiency of the company.	Operational Impact: High Productivity: Medium	- IT Support Manager - Service Desk	IT support provides technical support and maintenance for IT systems, to minimise downtime and protect data integrity, companies must follow secure IT processes and NHS cybersecurity guidelines.
25		Cleaning services	Low	High - Unhygienic environments can result in patients to become sick and can also disrupt the workflow. - Increases the risk of infections which can result in longer recovery times.	Regulatory Compliance: High Reputation: Medium	- Domestic services manager - Waste and Environmental Manager - Cleaning Supervisor - Infection Prevention and Control (IPC) - Clinical Nurse Specialist (CNS)	It is important that facilities are kept hygienically clean and ensuring that all waste products are safely disposed of. This process must follow proper health care regulations to ensure the safety of all users at the hospital.
26		Security Services	Medium	High - Can result in breaches and safety concerns, which can have serious effects for patient health and data integrity.	Safety: High Reputation: Medium	- Security Manager	- Security guards and system monitoring provide safety and ensures quick responses to any incidents like unauthorised access. Which helps maintain a secure environment.

27		Maintenance services	Low	Medium - Delays can lead to equipment downtime and operational inefficiencies, negatively impacting patient care and overall workflow.	Operational Continuity: High	- Estates Manager - Maintenance Supervisor	Regular service schedules reduce the risk of failures, ensuring that equipment remains functional and reliable. This should be managed according to NHS maintenance and operational standards.
28		Catering Service	Low	Medium - Food safety risks can cause problems such as contamination, which can cause sickness for patients. - Disruptions could cause, legal liabilities, causing dissatisfaction, especially for those with dietary requirements (vegetarians). - Legal consequences if food safety standards are not met.	Patient Well-being: High Regulatory Compliance: High	- Catering Manager	- Provides food services for patients: meal preparation, delivery to patient. - Ensures compliance with hygiene and dietary standards.
29	Software	Telemedicine platforms	Medium	High - Exposed patient data can result in identity theft. - Significant disruptions especially if patients are unable to use this software. - Legal repercussion and financial loss if data is stolen.	Operational Continuity: High	- Remote consulting - Telehealth Equipment Specialist - Clinical Engineer - Telehealth Coordinator - Data Protection Officer	- this software allows healthcare service to be delivered digitally. - Ensures compliance with healthcare regulations and data privacy standards.

30		Billing and Revenue Management Software	Medium	High - Could lead to billing issues and possible fraudulent transactions which would cause financial loss. - This could also lead to disruptions as it could delay payments.	Operational Impact: Medium Financial Accuracy: High	- IT support - Revenue Manager - Billing Officer	- This Software handles financial transactions and ensures accurate billing processing, following the NHS financial regulations. - To protect this system, have access control, encryption, and system monitoring tools.
31		Appointment Scheduling Software	Medium	High - Impacts like missed appointments and inefficient use of healthcare resources could occur. - Patients may also lose trust which could decrease their willingness to book appointments.	Operational Impact: High Patient Trust: Medium	- receptionists - IT support - Practice manager	- Software is used for scheduling and managing patients' appointments. - Reduces scheduling conflicts and (encryption, access controls, and compliance with NHS digital service and data protection standards).
32		Electronic Health Record (EHR) Systems	Low	Very High - Exposure of sensitive data. - Disruption of medical services affecting patients care. - Financial loss due to downtime and any legal consequences that could occur (GDPR) - Reputation damage.	Patient Care: Very High Trust: High	- Health Informatics Manager - Medical Records Manager	- This system is used for storing/managing patient health records (medical history of patients, treatments, medical prescriptions, and any tests) - EHR data should be kept encrypted, it should be regularly backed-up, making sure it complies with GDPR and UK data protection act standards.

33	Security	Defence Tools	Low	Very High - If defence tools are compromised in any way it can lead to (system breach, loss of sensitive data and disrupting services)	Reputation: Very High Regulatory fines: High Operational impact: Very High	- Cyber Security Manager - IT Security Manager	Defence tools (firewall, antiviruses, etc) are essential for keeping everything secure. It's important to make sure these tools are always up to date and are in line with NHS cybersecurity policies and regulatory requirements.
34		Physical Security (CCTV, Criminal Alarms)	Medium	High - If someone were to gain unauthorised access, it could lead to stolen data, tampering with information/devices, or even damage/theft to the physical assets.	Operational impact: High Reputation: High	- Security Manager - Facilities management	Physical security provides protection against unauthorised access to points providing physical protections (to protect valuable assets) all of this must comply with the NHS's security guidelines.
35		Access Control Systems	Medium	High - Breaches can cause issues such as unauthorised access, data theft, or equipment damages.	Reputation: High Operational impact: High	- Security Manager - IT security manager	Access control systems manage access based on roles and conduct regular audits ensuring systems are only accessible to members who require the data.
36		Intrusion Detection Systems	Medium	Very High - Critical to prevent unauthorised access to networks and systems, as this helps secure identifiable information and protects against potential data breaches.	Network Security: Very High Operational Impact: High	- IT Security Manager - Cyber Security Analyst	Constant monitoring ensures protection, helping to detect and respond to threats in real-time, which is essential for maintaining the integrity of healthcare data management and to meet NHS cybersecurity standards and regulatory requirements.

37	Intangible	NHS Reputations	Medium	Very High - If the reputation is damaged it can lead to the loss of public trust, funding cuts and can harm the flow of the organisation	Reputation: Very High	- GP Practice Manager - Communications Manager	Public trust is an essential if any damages were to occur, it could affect both funding and the delivery of services. This should be managed according to regulatory guidelines.
38		Patient Trust	Medium	High - This can result in patients to become less likely to seek medical treatment, which can negatively affect the NHS's reputation, cause harm to patients if they do not seek any treatments and can also reduce the funding.	Reputation: High	- Patient Experience Manager - Communications Manager	To improve reputation, the NHS must be transparent, satisfy patients and improve the care they provide this further increases the bond between hospital and patient.
39	Human	NHS Staff	Medium	Very High - If staff is not fully trained or having a lot of turnovers can disrupt service delivery. - This can compromise patient care - It may lead to legal issues	Operational impact: Very High Reputation: High	- Human Resources Director	It is important for staff to receive proper training in cybersecurity. As it can allow them to understand the different cyber threats that can occur and how they can overcome them such as phishing attacks.
40		IT Staff	Low	Very High - If anything were to happen to IT staff, it can result in staff taking longer to respond to incidents which can result in longer system outages and make the system more vulnerable to attacks.	Operational impact: Very High Reputation: High	- IT Services Manager - IT Asset Manager	IT staff is a specialised team which is crucial for keeping the system secure and responding to any possible cyber-attacks by following NHS best cybersecurity practices.

41		GPs	Medium	Very High - Loss of staff would cause disruptions with patient care and could lead to reputational damage and regulatory issues.	Reputation: Very High Operational impact: Very High	- General Practitioner (GP) - Practice Manager - Clinical Director	GPs are the key members involved in healthcare delivery, they are required to have the latest medical and security training in line with NHS guidelines.
42		Administrative Staff	Medium	High - It's important to manage sensitive patient and operational data carefully. Mistakes in handling this data can result in data breaches or delays.	Operational impact: High Reputation: High	- Administration Manager - Practice Manager	- This staff member is responsible for managing all NHS administrative tasks, ensuring that healthcare providers have a smooth operation. We need to have training on GDPR, data handling protocols, and specific processes to avoid accidental breaches or inefficiencies.
43		Maintenance Staff (cleaning, food staff, etc)	Low	Medium - Maintenance staff could accidentally create physical security risks or gain access to sensitive areas.	Reputation: Medium Operational impact: Medium	- Facilities Manager - Environmental Services Manager	- Maintenance staff are responsible for maintaining facilities like (plumbing, electrical and building maintenance) - Making sure background checks and restricting access to sensitive areas help reduce risk.
44		Specialist staff (Surgeons, dermatologist, radiologists)	Low	Very High - If specialist staff are unavailable for any reason, it can cause issues such as delayed or improper diagnosis/treatments which would severely effect patients health.	Reputation: Very High Operational impact: Very High	- Clinical manager - Department Heads	- These individuals provide important services mainly providing diagnosis for patients and preforming treatments which could include surgeries.

45		Reception Staff	Medium	High - If reception staff are unavailable or any issues occur it could lead to delayed responses to any emergencies which could affect patients' health.	Operational impact: High Reputation: High	- reception Supervisor - Practice Manager	- reception staff deal with calls and providing help to patients. - Important to have secure communication to manage emergency effectively.
----	--	-----------------	--------	--	--	--	--

4.2 Threat Actor Table:

This table below will discuss the following (Sailio, 2020):

- Threat actor = Individuals that may attempt to attack the NHS.
 - Motivation = The reasoning behind the attacks.
 - Attack Method = The type of attacks they usually use to obtain their desires.
 - Impact = The negative effects that the attack would have on the NHS.
-

Threat Actor	Motivation	Attack Method	Impact (Based on NHS)
Cyber Criminals	Mainly motivated by: (financial gain, political reasonings, personal vendettas, thrill-seeking, ideological beliefs)	- Ransomware (encrypt data) - Exploitation of security vulnerabilities. - Deployment of malware (trojan, spyware, viruses, worms) to gain data and system compromise - Social engineering tactics (using psychological manipulation) - DDoS attacks: overloading systems. - Phishing (steal login credentials or install malware onto devices)	1. Financial loss: - Downtime, ransom payment, recovery of system and penalty payments which could occur due to protection laws (DPA). 2. Reputation Damage: - Data leaks of patient/staff data could lead to loss of public trust. 3. Disruptions: - Significant delays like cancellations of patient appointments and operation outages (causing major setbacks) 4. Legal issues: - Facing legal repercussions like fine payments if standards like data protection laws are not met or comply with the cybersecurity regulations.
Hacktivists	Attackers are driven by political, religious or social reasonings to expose alleged wrongdoing, protest, or advance a cause.	- Defacement of websites (alter appearance to push own agendas political, religious or social reasonings) - DDoS attacks (disrupting major operations to protest or prove a point) - Campaigns (spreading misinformation to apply pressure to companies) - Exploiting vulnerabilities	Financial loss: - Disruption of services, recovery of systems and legal payments like the failure to follow GDPR. Reputation Damage: - Lack of confidence due to inability of keeping sensitive data secure. - Spreading misinformation would erode trust among patients, which creates a perception of vulnerability. Disruption - Cyber-attacks can cause disruptions to operations which could impact patients' health requirements not being checked properly.

			Data Leaks - Leak of patient data would violate privacy which could lead to legal consequences. - Identity theft and the exploitation of data (sold or misused in illegal activities)
Organised Criminal Groups	These individuals target organisations for the main purpose to assets which can then be sold for a profit.	- Phishing, Ransomware, DDoS attacks, Malware Transmission, Vulnerability exploitation, Social Engineering. - Physical theft to steal valuable assets (physical assets and money).	Financial loss: - Recovery costs, legal fines, ransom payments all of which causes financial strains on a company. Reputational damages: - Data breaches can cause the loss of trust between patients and the NHS, leading to negatively publicity and loss of patient confidence. Legal issues: - system recovery, ransom fees, system disruptions and legal penalties (fines) can create a financial burden. Disruptions: - Medical delays can occur due to equipment loss or system failure.
Insider Threats	- Employees may have grudges against organisation which can result in seeking revenge - employees may accidentally cause threats to companies like employees with the lack of security knowledge.	- Unauthorised access to restricted online/on-site facilities. - Human error: exposed credentials or weak credentials, misconfigurations and failure to implement security updates for devices. - Data leak which can occur accidental or intentionally leaked.	Financial Loss: - Recovery of damaged assets and legal penalties due to failure to follow regulations and guidelines Data Security: - Leakage of patient/staff sensitive data (credentials) Operational Impact: - delays within healthcare services and system downtime (puts patients health at risk).
script kiddies	-These hackers are motivated by the recognition of the public and the excitement of attacking well know organisations.	- Makes use of pre-written tools and scripts (exploiting already identified vulnerabilities or carrying out simple attacks like phishing, website defacement)	Disruption: - Temporary service outages there not so significant these outages could be defacing websites or stealing minor data, not so large-scaled. Reputation damages:

			- Simple methods can highlight to the public vulnerabilities within security which could cause public trust to be negatively affected, especially due to small, scaled attacks which could be prevented easily. Increasing security threat numbers: If vulnerabilities were exploited, it would raise attention to advanced hackers, providing an opening of a vulnerability that can be taken advantage of, which would increase the damages.
Environmental Threats	Natural disaster or biological risks	- Flooding, Fire, Earthquakes (Damaging infrastructure and systems). - Microorganisms and Pests (Causing health risks, contamination of equipment). - Weather Conditions (Impacting power supply, communication networks). - Pandemics and Staff Shortages (Reducing workforce availability).	System Downtime: - Disrupting healthcare services. Data Loss: - Damage to physical servers and other physical assets. Financial Burden: - Recovery and replacement costs.
National State actors	Members that are associated with government members engage in cyber operations to advance national interests, often targeting other nations' infrastructure, stealing sensitive information which can be used for their strategic advantages	- Spying (conducting surveillance on nations, economic, political or military data) - Cyber-attacks targeted towards critical services - Developed Malware (Develops malware or tools to attack specific opponents) - Misinformation (manipulate or influence public opinion, election interference)	National security risks: - They can use information for intelligence purposes. not only would this pose a threat to individuals' privacy it would also threaten our national security. potentially exposing sensitive information that could be exploited against us. Financial loss: - Due to the severity that these attacks cause to organisations costs for both mitigation and recovery will be significantly more expensive. Operational Disruptions:

			- This would apply a strain on companies more specifically (delays with medical appointments and decrease in the quality patient care).
Terrorist Organisation	These groups are motivated by ideological beliefs, political concerns, or religious extremism, which usually drives them to carry out attacks to further their beliefs or instil fear.	- Recruitment plans through social media platforms (targeting people who are more vulnerable) - Spreading misinformation and threats aiming to spread fear and disrupt public trust. - Harm to essential operations either through physical attacks or cyber-attacks (aiming to disrupt important operations)	Operation Disruptions: - Delays to critical healthcare responses which could endanger patients' health if the necessary healthcare services are unavailable. Public Panic: - Misinformation, threats and attacks can cause the public to become more fearful and overwhelmed by terrorists which can negatively impact the healthcare response. Financial damage: - Significant damages result in significant recovery costs and security reinforcements (It will be expensive).
Supply Chain Attackers	These attackers target vulnerabilities within supply chains aiming to either disrupt healthcare operations or to gain sensitive information of either the supplier or the organisation that receives the supplies.	- Integrate malicious software within developed products or software patches. - Social engineering tactics (phishing to trick staff to gain access to information) - Compromising vendors (targeting weak points within security to gain access to the primary organisation)	Security issues: - Supply chains can act as a access point to gain access to the primary organisation. Financial loss: - Loss of supplies due to unavailability or delays can result in unnecessary loss of funds to reinvest for resupply of unavailable stock. Disruptions: - If medical supplies are unavailable, it could cause the delay of medical treatments which would impact patients' health if treatments aren't available.

Competitor Organisations	Companies carry out attacks to reduce competition by getting a competitive edge.	- Employment of competitor staff (hiring rival company employees usually providing greater benefits e.g. increased pay) - Spreading misinformation (negatively affecting the competitor's reputation) - Corporate espionage (stealing important company information to gain a competitive edge)	Financial Loss: - Loss of research which could cause funds to decrease and growth - Competitive disadvantage Reputation Damage: - Stolen information and innovations being used in other project can cause the companies credibility to decrease. Operational Impact: - Decrease funding - Becomes difficult to attract patients
Financial Fraudsters	These individuals are mainly motivated by monetary gain.	- Social engineering tactics (usually using phishing to trick individuals into providing any financial information) - Identity theft (Stealing credentials to access financial accounts) - Investment and credit card Fraud (Scamming individuals with false investment opportunities, unauthorised transactions).	Monetary Loss: - Loss of funds due to fraudulent claims which would lead to financial strains. Data Breach: - Patient identities are taken for fraudulent purposes, harming privacy and personal data. Legal Risks: - Examinations of NHS security flaws, which may lead to legal repercussions and a loss in public confidence.
Medical Data Brokers	They collect and sell personal information, often leveraging cyber-attacks to access medical records, compromising patient privacy for money.	- Data Aggregation (collecting patient information from multiple sources forming a profile) - Cyber-attacks (Hacking databases to extract information) - Illegal Sales (Selling confidential health information to third-party organisations)	Privacy Violation: - Selling patient data, is a violation of patient confidentiality which would result in NHS to face consequences such as penalties. Legal Consequences: - Liability for data protection failures, which would lead to lawsuits and fines. Loss of Trust: Public fear over privacy breaches which results in the loss of trust with the NHS.

Social Engineer	Motivated by many factors, primarily personal gain. includes (financial gain, access of sensitive data, thrill of deception).	- Psychological manipulation (tricking people into giving up confidential information)	Unauthorised access: - Infiltrating on-site or compromising endpoints. - Compromising login credentials. Data Exposure: - Sensitive data at risk for malicious use (e.g. gaining unauthorised access to sensitive rooms, files) which can jeopardies the organisations security and integrity. Financial and reputation loss: - Potential financial loss due to fines or recovery costs. - Significant loss of public trust. if users feel that their information isn't secure, it can have lasting effects on how they view the organisation.
Unintentional threat actors	These are individuals or entities that inadvertently cause security incidents.	- Accidental exposure of sensitive data (weak passwords, misconfigurations, negligent exposure and unpatched systems) - Social Engineering tactics (phishing, baiting, shouldering, etc.)	Data Breaches: leaked data can lead to significant privacy violations resulting in legal consequences. - If information like credentials is leaked it could lead to issues like unauthorised access to systems or on site both of which could harm the functionality of the health care providers. Operational Impact: - Human error like system misconfigurations can cause system downtime, disrupting healthcare services and patient care. Financial Cost: - NHS would have to spend costs on training, security fixes to prevent future incidents, and possible recovery costs if any damages occurred.

5 Risk Register:

The risk registers job is to document the potential risks that could affect the Hospital.

note: likelihood, impact, risk level and cost are rated using these scales (**Low, Medium, High, Very High**)

- **ID** – risk identification.
- **Risk** – description what the risk is.
- **Vulnerability** – Weaknessess which would allow the risk to happen.
- **Likelihood** – The probability that the risk where to occur. seminar 6
- **Impact** – The damages level it would cause (calculated using CIA triad). seminar 6
- **Risk level** – How Sevier the risk is (Impact x Likelihood=risk level). seminar 6
- **Action** – step-by-step process to mitigate the risk.
- **Control** – to mitigate/prevent the risk.
- **Cost** – The financial loss caused by risk.
- **Plan** – the long-term ways to mitigate risk from occurring.

Scale range for Likelihood:

- **Low:** (4 to 6)
 - **Medium:** (7 to 9)
 - **High:** (10 to 12)
 - **Very High:** (13 to 16)
-

ID	Risk	Asset	Vulnerability	Likelihood (Network, Process, People, Business)	Impact	Risk Level (Impact x Likelihood)	Action	Control	Cost	Plan
1	Unauthorised access to sensitive data	1,2,4,5,7,9	- Compromission of login details (can occur due to weak details such as passwords). - No authentication in place to prevent any possible brute force attacks. - Unawareness of system monitoring - SQL statements can be edited through system. - Staff unaware of security issues.	1. Network: High (3) 2. Process: High (3) 3. People: Medium (2) 4. Business: High (3) 3+3+3+2=11 Convert using ranges Total: High	Very High exposed sensitive data can affect confidentiality (potential fines and reputation damage). could also cause widespread operational disruption. The consequences are severe and potentially irreversible without immediate action.	Very High * High = Very High	1) remove access to all compromised accounts. 2) carry out investigation to determine the extent and cause of the breach. 3) Inform all affected individuals. Provide clear information about what happened and what steps they should take to protect themselves. 4) Report the breach to relevant authorities as required by law. 5) Update security policies and monitoring systems for any signs of unauthorised access or suspicious activity.	Procedural: - Regular training (excellent cybersecurity practices and understanding how to handle security issues) - Regular audits of access permissions to ensure only authorised users have access. Technical: - Implement multi-factor authentication - Encryption of both rest and transmitted data - Role-based to restrict access to data not necessary to job. Physical: - Restrict onsite access to sensitive buildings (server rooms).	High	- Having regular staff training on security awareness can teach how to be safe online. - Regular penetration testing to identify vulnerabilities within systems (websites, etc). - Have Authentication system in place as it prevents any possible brute force attacks. - Continuous monitoring of system to identify any possible harmful activities. - Implement strong encryption methods for both storing and transmitting sensitive data. - Update security policies to reflect current threats and best practices.
2	Data loss, corruption and unauthor	7, 10, 11, 14, 32	- Vulnerabilities within software (can be caused by outdated software).	Network: High (3) Process: High (3)	Very High Data risks integrity, confidentiality, and availability of sensitive data.	Very High * High = Very High	1) Carry out data recovery steps using the most recently saved backup. 2) Inform all affected departments of the	Procedural: - backup policies and recovery drills. Technical:	Very High	- Conduct mock recovery drills to test and improve recovery protocols. - scheduled backups ensuring that there is both

	ised alteration (accidental deletion, ransomware attacks)		- Weak cyber security measures (no protection like antiviruses). - No backup systems in place or damaged backups of system.	People: Medium (2) Business: High (3) $3+3+3+2=11$ Convert using ranges Total: High	Loss/corruption can cause system downtime, financial losses, and reputational damage. Even with controls like backups, the risk of irreversible data loss and its effects on operations is very high.		incident and any possible consequences. 3) After recovery steps conduct a detailed assessment of data integrity post-recovery and put in place new measures to prevent the possibility of future occurrences such as staff training.	- automated patch management to decrease vulnerabilities (new security features). - strong encrypted backups. Physical: - Secure backup storage.		an on-site and off-site backup (for reliability). - Have backups encrypted (strong encryption). - Keep backups on multiple sites, ensure if the main sites backup fails there are still more available. - Using (DLP) to monitor and prevent unauthorised sharing or the loss of sensitive data. - Regular scheduled security patches.
3	Insider threat	1, 4, 5, 7, 8	- Employees that have a grudge against the company. - not enough access controls. - lack of monitoring on staff activities (what data they are accessing).	1. Network: Medium (2) 2. Process: High (3) 3. People: Medium (2) 4. Business: Medium (2) $2+3+2+2=9$ Total: Medium	Total: High Serious risk to data confidentiality and integrity since insiders can access/leak sensitive information. However, the impact is rated as High instead of Very High since organisations often have controls like audits and monitoring. These measures help catch insider actions early, preventing major disruptions. While damage can be	Medium * High = High	1) Identify individuals who were involved and what data might be at risk. 2) Contain the situation by limiting blocking access to any suspected individual. 3) Investigate to gather evidence and figure out the motivations behind the threat. 4) Notify authorities of the incident. 5) Take steps to improve security measures and make sure to monitor for any signs of threats to prevent recurrence.	Procedural: - Have clear access policies only allowing employees access to necessary data to perform their daily tasks. - Monitoring (regular audits) to detect and flag any unusual activities (unauthorised access of data). Technical: - DLP tools to prevent insiders from carrying out activities like data transferring. Physical: - Secure access using biometric/keycard systems	Medium	- Having access control system to limit access to sensitive data based on roles and responsibilities (job requirements). - Security Information and Event Management (SIEM) helps with tracking malicious activities like unauthorised access to sensitive company data. - Implement staff training teaching security policies, ethical behaviour, educating staff on possible consequences of malicious intents.

					significant, it is usually more contained and reversible compared to external breaches.			to prevent unauthorised site access. - Implement a revoke system to deny staffs access to previous job systems (staff that leave the organisation or change roles) to prevent employees from having access to sensitive data, which they shouldn't have access to, helps with preventing former staff from stealing company property (data).		
4	Cyber Threats (Malware, Ransom ware)	1, 13, 30, 31, 32	Can occur from many factors: - unpatched software (e.g. not updated antiviruses or other security tools). - staff do not have necessary knowledge of cyber security (e.g. they don't understand strong password policy, how to identify phishing attacks). - failure to conduct regular security audits which can	1. Network: High (3) 2. Process: High (3) 3. People: Medium (2) 4. Business: High (3) 3+3+2+3=11 Total: High	Total: Very High Severe risk to the confidentiality of sensitive data through unauthorised access, while the integrity of critical systems may suffer from data corruption/loss. Additionally, IT system availability can be greatly impacted, potentially making essential services unusable. resulting disruption and financial losses can be severe and	High * Very High = Very High	1) Identify cyber-attack by identifying signs of infection or unusual behaviour. 2) Isolate all affected systems to help stop any further spread of malware. 3) Remove malware using security tools like antivirus or other tools. 4) if data is either damaged, removed or encrypted make use of backups to restore compromised data. 5) Update security software to make sure that bugs are patched to	Procedural: - Regular security update ensures that existing bugs and vulnerabilities are kept patched which reduces vulnerabilities. - Training staff can provide knowledge to staff of security risks which can help in detecting and handling risks. Technical: - Deploying security tools (antiviruses) can detect and remove any possible harmful malware protecting systems. intrusion detection.	Very High	- Training staff to understand cyber threats to ensure that they can recognise potential risks and ways to respond to potential attacks effectively. - Make sure all software and operating systems are updated with the latest security patches protecting systems from any new security threats. - Implement security software (antiviruses, firewall) to identify, block and remove any possible security threats (malware).

			allows malicious activities to occur without any notice.		often irreversible without immediate intervention.		protect system from any possible upcoming attacks. 6) Educate users on safe practices to avoid similar threats.	- Conduct regular penetration tests to identify vulnerabilities and patch identified exploits. Physical: - Secure server facilities to prevent unauthorised access.		- Carry out regular scheduled pen test to identify any possible vulnerabilities which could pose a threat if exploited. - Perform penetration tests to help identify any weak points within software's.
5	System Downtime	13, 14, 15, 16, 21, 29	- System downtime can occur due to reasoning like hardware or software being either damaged or outdated some example attacks that would affect systems are like DDoS attacks.	1. Network: Medium (2) 2. Process: Medium (2) 3. People: Medium (2) 4. Business: High (3) 2+2+2+3=9 Total: Medium	High System downtime causes disruptions which can affect the (availability) of critical operations which can affect company operations. However, organisations who implement (backup systems and incident response protocols) can help mitigate and fix downtime within an acceptable timeframe. While there is the risk of data loss and potential operational delays, these	Medium*High=High	1) Firstly, implement a backup of the system to help with minimising any further disruptions until systems can be brought back. 2) notify any users who are affected by this issue making sure to notify them alternative solutions that they can use in the meantime. 3) Next identify the cause of the downtime and in this process implement the necessary methods to restore systems making sure that everything runs as it is supposed to function.	Procedural: - Develop an incident response and a communication plan. Technical: - Load balancing can distribute incoming network traffic across multiple servers. It can also detect server failures and reroute traffic automatically, enhancing resilience. - Regularly test failover procedures to ensure smooth transition during outages. - Keep real-time monitoring of systems to detect any system failure or performance issues.	Medium	- Schedule regular stress tests to assess the system's performance under high loads. This can identify potential weaknesses and bottlenecks. - Set up failover mechanisms: where if one component fails, another can take over without significant disruption. - Monitoring tools to keep track of system performance and health. alerts for any performance issues, allowing for quick responses to issues.

					compensating controls prevent the impact from reaching a "Very High".			Physical: - Run maintenance on physical device ensuring that they are secure and functional		
6	Equipment failure (all medical devices example MRI scanners)	3, 17, 19, 20	- Old equipment (may have outdated software which can be prone to cyber-attacks) - lack of maintenance which can cause the equipment to be unpatched or there could also be undetected damages that require fixing. - if there is a lack of physical security there is a good chance that the equipment can be damaged physically.	1. Network: Medium (2) 2. Process: Medium (2) 3. People: Medium (2) 4. Business: High (3) 2+2+2+3=9 Total: Medium	High Failure of critical medical devices disrupts patient care and diagnostic accuracy (integrity and availability issues). However, regular maintenance and spare equipment limit the duration of the impact, preventing any catastrophic outcomes.	Medium*High=High	1) identify the main issue with equipment making sure to check any problems like (software error messages, power outages, etc). 2) Isolate the affected device for patient safety and prevent further issues. 3) Notify maintenance or technical support for professional assistance. 4) Document the issue and any actions taken for future reference.	Procedural: - Enforce regular maintenance and asset audits. - Implement training programs to ensure staff can identify and handle equipment malfunction allowing the company to run as normal with minor disruptions even during inconvenient times. Technical: - Conduct regular maintenance on equipment to identifying any potential issues and the health of equipment before it becomes a major issue. Helps reduce chances of equipment failure if equipment is handled well with the necessary repairs. Physical: - Maintain an inventory of spare equipment or parts	High	- Have daily scheduled maintenance of equipment to keep track of the health of equipment. - Maintain backup equipment to ensure that if any equipment becomes unusable, hospitals can use it to prevent disruptions in operations. - Conduct routine inspections to identify any potential issues early. This ensure that equipment remains functional and minimises the risk of disruptions in hospital operations.

								to ensure quick replacement or repair during equipment failure, ensuring continuous operation.		
7	Supply chain disruption	22, 23, 28	- Natural disasters, geopolitical factors, and technological failures can significantly disrupt supply chains. - Poor communication with suppliers and large demands can contribute to vulnerabilities in the supply chain.	1. Network: Medium (2) 2. Process: Medium (2) 3. People: Medium (2) 4. Business: High (3) 2+2+2+3=9 Total: Medium	High Delays in critical medical supplies can significantly disrupt operations and patient care (affecting availability and integrity of service delivery), however existing contingency measures help prevent a catastrophic outcome.	Medium*High=High	1) Identify the reasoning for the delay by communicating with the suppliers. 2) Assess the impact on operations and prioritise critical supplies needed immediately. 3) Seek alternative suppliers or sources to fulfil urgent needs. 4) Communicate with stakeholders, including staff and patients, about potential delays and solutions. 5) Implement contingency plans to manage the situation until normal supply levels are restored.	Procedural: - Create contingency plans that outlines steps to take if unexpected disruptions where to occur (strategies to minimise the overall effect). - Have multiple suppliers to avoid dependency on one single source. This reduces disruptions if a supplier is unable to deliver. Technical: - Implement tracking software to monitor supplies in real-time. allowing for quick response to disruptions, minimising delays and rapid resolution. Physical: - Keep well supplied making sure to possess enough supplies if delays within supply chain where to occur.	High	- Build relationships with multiple suppliers to reduce reliance on one source and mitigate risks from supplier failures. - Develop clear action plans for disruptions, including emergency contacts and communication protocols, and regularly review and update these plans. - Use advanced systems for real-time data analytics to optimise stock levels and maintain safety stock for essential items.

8	Power outages	13, 14, 15, 16	- Single power sources increase the risk of total system failure during outages. - Insufficient backup power solutions can lead to prolonged downtime. - The lack of regular generator testing may result in unpreparedness when power outages occur, as generators might fail to operate when needed most.	1. Network: Low (1) 2. Process: Medium (2) 3. People: Low (1) 4. Business: High (3) $1+2+1+3=7$ Total: Medium	High Sudden power outages can disrupt critical operations and cause data corruption. However, backup systems and regular testing help mitigate this risk, keeping the consequences from reaching a "Very High" level.	Medium*High=High	1) Identify the reasoning of the power outage if it's identified that the cause is due to damages (then assign technicians for repairs so that services can be back and running). 2) Turning off and unplugging sensitive equipment that's not in use to prevent any possible damage. 3) Use backup power generator for essential services. 4) Communicate with staff or affected individuals about the situation and expected duration. 5) Monitor the situation and be prepared to implement emergency protocols if necessary.	Procedural: - Make use of backup power supplies to provide immediate power to critical systems during a power outage, keeping major operation running even through major setbacks and helps in minimising disruptions. - schedule regular generator tests to check the readiness. - Provide prioritisation for critical operations this both helps so that major operations are not severely impacted and helps with electricity not being wasted on nonmajor tasks (allows major operations to have a larger supply). Technical: - Use UPS systems and power monitoring can detect and manage power fluctuations. Physical: - Apply regular maintenance on both power supplies and backups to ensure that they function properly when needed confirming	Very High	- Install backup generators to ensure that there is continuous power even if the main supply is unactive. - Have regular maintenance and testing of power systems to make sure that they function properly. - Have real time monitoring systems to detect possible power issues which can help minimise. - Implement on site security (CCTV, security guards, regular monitoring systems) to prevent any attempts of damaging of important facilities (power supply).
---	---------------	----------------	---	---	---	------------------	--	--	-----------	--

								that if an outage where to occur there is still a system to fall back onto. - secure power lines to decrease the risk of physical damage or tampering.		
9	Human Error	1, 2, 6, 7, 8, 10	- Insufficient training on critical jobs can lead to increased risk of errors. - Reliance on manual workflows may result in delays and human mistakes during operations. - Lack of automated error-detection mechanisms can prevent timely identification and correction of issues, increasing	1. Network: Medium (2) 2. Process: High (3) 3. People: High (3) 4. Business: High (3) 2+3+3+3=11 Total: High	High Errors can compromise data integrity and operational efficiency, causing significant disruptions. However, controls (regular training, peer review) can help decrease damages and prevent a significant impact.	High*High =High	1) Identify the error by reviewing the situation and gathering any information based on the error. 2) Assess the impact of the error on operations or outcomes. 3) As soon as possible correct the mistake as quickly as possible to minimises any further damages. 5) Analyse the root cause of the error to understand why it occurred. 6) Implement training or process improvements to	Procedural: - Train staff to strengthen their understanding and preparedness of their job, ensuring they can perform tasks correctly. - Peer review allows extra validation for critical operations, ensuring no errors before submission by verifying the job. Technical: - Automate tasks that are prone to errors and are very repetitive this ensures consistency and reduces the need for human input	Medium	- Conduct regular training tailored to key tasks (e.g security awareness courses, refresher training). - Automate repetitive or high-risk processes where feasible. - Introduce peer-review systems for critical decision-making tasks such as making diagnosis. - Implement more automated validation systems to reduce mistakes made by staff.

			the likelihood of adverse outcomes. - Incorrect configuration of systems				reduce the likelihood of similar errors.	decreasing chances of errors. Physical: - Optimise workstation setups to improve productivity.		
10	Medication delivery errors	6, 10, 32	- When workflows are complicated and not easy to follow, it can really slow down staff and make their jobs tougher. - If medication labels aren't clear, it can create confusion, leading to mistakes that could put patients at risk. - Not having a reliable double-check system during dispensing increases the likelihood that errors might go unnoticed, which could have serious impacts on patient care.	1. Network: Medium (2) 2. Process: Medium (2) 3. People: Medium (2) 4. Business: Medium (2) 2+2+2+2=8 Total: Medium	High Incorrect medication delivery harms patient safety by impacting treatment and service availability. While protocols are in place, complex workflows and unclear labelling can cause serious errors. These can often be addressed quickly.	High*Medium=High	1) Identify the error by reviewing the medication delivery records. 2) identify impact that's been caused (harm to patients). 3) Correct the delivery mistake by administering the correct medication making sure it gets delivered and notify the healthcare team about the situation.	Procedural: - Standardise protocols to ensure consistency in procedures (training, reviewing) - Implement double-check systems to keep track of deliveries. Technical: - Use barcode scanning and electronic records (verify and keep track of delivery). Physical: - Improve medication storage (using categories) and labelling (keep labels clear bold fonts).	Medium	- Revise protocols regularly and adapt to new best practices, ensuring they remain effective and relevant. - Enhance labelling clarity using (simple language, large fonts, bold text) to improve readability. - Deploy technological aids, for real-time medication tracking and alerts, to assist staff in managing medication delivery more efficiently and accurately.

11	Reputation Damage	37, 38	- Bad communication during issues can cause public distrust and negative perception. - Lack of transparency about incidents. - Failure to learn from past incidents and improve processes can result in repeated mistakes, further harming reputation. - Delayed responses to incidents.	1. Network: Low (1) 2. Process: High (3) 3. People: Medium (2) 4. Business: High (3) 1+3+2+3=9 Total: Medium	Medium Reputational harm mainly affects stakeholder trust instead of the CIA directly. While crisis communication and PR can help, ongoing negative exposure can lead to serious financial and operational consequences.	Medium*Medium=Medium	1) Firstly, understand how the reputation was damaged by gathering information about the incident (like data leaks). 2) work out the impact on the organisation including the potential financial or relational consequences. 3) Develop a response that addresses the concerns raised. making sure when communicating to be as transparent with the public to help rebuild trust.	Procedural: - Having a prepared communication plan can help in reducing concerns of any issues especially if it's well-developed and quick at response. - Provide well-structured training to staff to handle any patient concerns or issues that may arise. Technical: - Regular monitoring of media platforms can allow organisation to address any issues that arises.	Medium	- Develop and communicate clear policies for incident resolution. - Engage with the public through media. - Conduct surveys to gather feedback and address concerns promptly.
12	Loss of public trust	12, 37, 38	- lack of communication about challenges that impact services. - Negative media influence highlighting operational issues. - Inconsistent service delivery leading to frustration.	1. Network: Medium (2) 2. Process: High (3) 3. People: High (3) 4. Business: High (3) 2+3+3+3=11 Total: High	High A loss of public trust damages the organisation's reputation and revenue but doesn't directly affect critical operational systems (CIA triad). Crisis communication and feedback mechanisms can help restore trust.	High*High=High	1) Identify the issues that caused the loss of trust. 2) Identify the impact (damage to reputation, relationships with public). 3) Create a response to address the concerns and outline the steps being taken to fix the issues.	Procedural: - Create clear service protocols - Implement customer feedback systems. Technical: - Implement CRM tools and social media analysis to gather information. Physical: - Provide pleasant staff at locations to provide	Medium	- Honest communication with public to build trust. - Respond to incidents quickly and effectively to show commitment. - Run public campaigns to share improvements and successes in delivery, making it relatable to the community.

			- Lack of transparency regarding incident, causing scepticism among the public.					positive experience for patients		
13	Physical theft of equipment	13, 14, 17, 20	- Weak security can leave assets vulnerable. - No surveillance makes it easy for thieves to enter unnoticed. - Poor access controls allow unauthorised entry. - Lack of security guards delays responses to suspicious activities.	1. Network: Low (1) 2. Process: Medium (2) 3. People: Medium (2) 4. Business: Medium (2) 1+2+2+2=7 Total: Medium	Medium Stolen equipment can expose sensitive data which can compromise confidentiality and disrupt operations by reducing availability, leading to significant operational and reputational consequences.	Medium*Medium=Medium	1) Conducting a checkup to confirm the missing equipment that was stolen. 2) Report the stolen equipment to the police and any information. 3) Notify staff about the situation and any potential impacts. 4) If equipment isn't returned then lost equipment will have to be reordered to make sure staff don't have insufficient equipment.	Procedural: - Regular security assessments and access logs. Technical: - Implement tracking systems for valuable assets to facilitate easier retrieval if stolen. Physical: - Implement a key system to gain access to sensitive areas (key could be biometrics or keycard) - Encase more valuable assets with locks, barriers, or safes to make it difficult to gain access. - Install (CCTV, sensors, alarms) to monitor activities, this discourages stealing and provides evidence if anything is stolen.	Medium	- Perform regular security assessments to identify vulnerabilities. - Implement biometric access/key card systems to control who can enter secure areas. - Secure equipment by implementing anti-theft systems and physical fencing to prevent the removal of equipment. - Train staff on security protocols to ensure everyone knows how to respond. - Use CCTV, security guards and security alarms to monitor sensitive areas and deter theft. - Regularly update security measures to adapt to new threats. - Conduct drills to prepare for potential security breaches.
14	Environmental	13, 14, 15	- Poor disaster preparedness can	1. Network: Low (1)	High	High*Medium=High	1. Identify the type of hazard (e.g., floods).	Procedural:	High	- Prepare detailed hazard (like flooding) response

hazards (natural disasters)		leave organisations vulnerable during emergencies. - Inadequate building protection increases the risk of damage from natural disasters. - Lack of emergency plans can lead to confusion during a crisis. - Weak building structures can result in severe damage or collapse. - Not having backup systems can lead to data loss and operational disruptions. - Regular drills can help ensure readiness for disasters.	2. Process: Medium (2) 3. People: Low (1) 4. Business: High (3) 1+2+1+3=7 Total: Medium	They can severely damage physical infrastructure and IT systems, leading to significant operational disruption availability and potential data loss integrity. With effective disaster recovery plans in place, the overall impact is contained, which justifies a High rather than a Very High rating.		2. Depending on the type of hazard use the emergency response plan (that is designed for that specific hazard) that outlines procedures for evacuation, communication, and resource allocation during a disaster.	- Create a disaster and business continuity plans to ensure operations can resume quickly after a disaster. - Regular emergency response drills to ensure staff are prepared to act quickly and efficiently if hazard where to occur. - Make regular evaluations on site ensuring no possible hazards which could endanger users if a natural event occurred. - Making sure harmful waste products are safely disposed, minimise wastages and being more ecofriendly can decrease the environmental impact. Technical: - Implement continuous monitoring to detect strength levels of the weather, allow quicker preparations if the strength is high. - Have regular backups of data (cloud) to prevent data loss and simple recovery process. Physical:	protocols for effective action. - Implement emergency response training to ensure employees are ready to handle situations (e.g. fire outbreaks). - Have backups of important equipment and data to ensure business continuity in case of facility damage. - Make investments into infrastructure improvements (reinforced buildings, flood defences, Permeable Pavements, etc) to protect sites from disasters.
------------------------------	--	---	--	--	--	--	---	---

								- Invest into stronger protection (flood barriers) ensuring that they are strong enough to protect against natural disasters.		
15	Disease outbreaks (pandemics like covid-19)	1, 8, 10, 11, 39	- Insufficient pandemic preparedness plans can lead to chaos during health crises. - Lack of clear guidelines can hinder response efforts. - Not having adequate resources can strain healthcare systems. - Delayed communication can increase public confusion and anxiety.	1. Network: Low (1) 2. Process: Medium (2) 3. People: Medium (2) 4. Business: High (3) 1+2+2+3=8 Total: Medium	Very High An outbreak can overwhelm healthcare operations, leading to service disruptions and loss of continuity (Availability). Resource strain undermines care integrity, and public trust can collapse due to patient management failures.	Medium*Very High=Very High	1) identify the outbreak. 2) contain the outbreak so that no further spread can occur (isolate patients into separate rooms). 3) notify all staff of the issue to make sure they are prepared with helping. 4) provide necessary treatment to patients until they are fully recovered.	Procedural: - Enforce strong hygienical and safety protocols to reduce the spread of outbreaks. - Following government guidelines always can ensure compliance with safety measures. - Keeping communication to all staff clear outlining all protocols and any updates regarding the outbreak. Technical: - Keep most operations which don't require to be in person to be done remotely from home. - Implement remote monitoring to monitor critical operations. Physical: - Have isolation facilities for patients with the disease to reduce the spread. - Ensure there's a large supply of protective equipment (suits, masks,	High	- Establish remote healthcare infrastructure so that staff can work remotely allowing health care providers to work continuously. - Expand emergency supply storage ensuring healthcare providers have enough equipment to assist if an unexpected outbreak where to occur where equipment is in high demand. - Train staff on pandemic protocols to ensure they can handle stressful situations (managing large number of sick patients). - Conduct regular drills to ensure staff readiness for emergencies.

								gloves, etc) for the safety of employees.		
16	Delayed medical emergency response	18, 21, 23, 24	- Caused by insufficient training of staff making them more prone to error for the job that staff carry out. - Old/damaged technology, software or vehicles can cause many issues. - If systems are already under attack, it can cause delays with responses,	1. Network: Medium (2) 2. Process: High (3) 3. People: High (3) 4. Business: High (3) 2+3+3+3=11 Total: High	High Delays in emergency response can compromise patient safety and continuity, impacting data integrity and critical services. Even with corrective measures, rating immediate operations high due to potential serious consequences.	High*High=High	1) Have patients' health checked making sure they perfectly fine. 2) Emergency services should then be notified as soon as possible about the situation. 3) While waiting for services to fix systems, patients' health should be kept monitored making sure if any medical treatment needed can be given in that time.	Procedural: - Train staff members with the knowledge of quickly identify and respond to any medical emergencies. Technical: - Implementation of data sharing tools for quick communication among staff ensuring they are aware of the situation. - Implement automated alerting system to notify all users immediately during emergencies. Physical: - Ensure that emergency equipment is easily accessible and available in every room and hallways.	High	- Hire more staff to assist with peak time emergencies. - Invest into more advanced communication to improve coordination between dispatchers and responders. - Provide regular staff training to help with response techniques and crisis management. - Conduct regular emergency drills to identify any possible weaknesses that require improvements.
17	Loss of staff	39, 40, 41, 42, 43, 44, 45	Loss of staff could occur due to illnesses or medical issues, lack of critical knowledge retention and poor work environment	1. Network: Medium (2) 2. Process: High (3) 3. People: High (3) 4. Business: High (3)	Very High Loss of key staff erodes critical knowledge and disrupts operations, leaving the organisation vulnerable to process	High*Very High=Very High	1) Make use of temporary coverage plan to fill gaps, such as redistributing tasks among remaining staff. 2) Recruit new staff quickly to replace the staff that are gone.	Procedural: - Have backup staff members (part time or temporary) for quick deployed during staff shortages. - Implement cross-training to provide staff skills to	High	- Train staff to be able to work multiple roles ensuring operations to run smoothly if members of staff are absent. - Deploy comprehensive employee retention strategy to keep staff

			which can result in low staff moral.	2+3+3+3=11 Total: High	failures. inadequate succession planning and high turnover directly compromise the People domain, severely affecting (CIA).		3) Provide support for remaining staff to manage increased workloads.	cover other jobs which mitigates the impact of departed staff. - Ensure key tasks, processes and knowledge is kept well documented to minimise disruptions. Technical: - HR management systems which can help streamline recruitment and performance management processes.		motivated to stay at the company methods (pay raise, promotions and benefits). - Create relationships with staffing agencies to quickly access temporary workers when staff members aren't available.
18	misdiagnosis	1, 3, 10, 11, 20	- Human error can cause incorrect diagnosis to patients. This usually can occur due to untrained staff. - diagnostic equipment that's (damaged/old) also result in misdiagnosis.	1. Network: Medium (2) 2. Process: High (3) 3. People: High (3) 4. Business: High (3) 2+3+3+3=11 Total: High	High A misdiagnosis may affect a patient's safety and course of treatment, sometimes resulting in legal problems and a decline in public confidence. However, current mitigation strategies, such as double-check procedures, aid in limiting the harm and preventing an extremely high impact.	High*High =High	1) Identify the misdiagnosis and pause the current treatment ensuring that patients don't receive incorrect treatments. 2) Ensure that patients are notified about the situation. 3) Ensure that the patients diagnose is reevaluated making sure it is doubled checked before it is given to the patient.	Procedural: - Regular training for staff. - Implement double-check and peer review systems to enhance accuracy. Technical: - Utilise up-to-date diagnostic equipment to ensure precise and efficient testing. - Maintain robust (EHR) systems for accurate patient data management and easy access to medical histories. Physical: - Ensure well-maintained clinical environments that support safe and effective patient care.	High	- Having regular training programs can help staff both refine their skills and learn more knowledge. - Having double checking system in place to check that diagnosis is correctly identified. - Keep diagnostic equipment well maintained ensuring software is updated and ensuring no physical issues.

19	Social engineering	1, 4, 13, 39, 42	- Lack of authentication can make it easier for attackers to falsely impersonate as a trusted staff member. - Members lacking knowledge of common manipulative tactics can increase the chances of being exploited (common attacks like phishing).	Network: High (3) Process: Medium (2) People: High (3) Business: High (3) 3+2+3+3 = 11 Total: High	High This method exploits human weaknesses and errors which can allow the attacker to gain unauthorised access. this attack can compromise confidentiality, damage the integrity and availability. however, having training programs and implementing strong authentication systems can help reduce these impacts	High*High=High	1) verify the social engineering attack and notify staff (security guards and IT support). 2) contain the threat and ensure that all affected areas meet the required treatments. 3) Assess the impact that has occur and gather evidence to notify police.	Procedural: - Implement training programs to provide security awareness (how to distinguish attacks like phishing emails). Technical: - Use email filtering and multi-factor verification for sensitive requests.	Medium	- Implement regular training programs on security threats for easy identification of common social engineering tactics. - Develop a clear incident response protocol if an attack where to occur
20	Assault/trespassing	25, 26, 27, 33, 34, 35, 36	- Weak physical security systems. - Weak surveillance systems either that they are damaged or not enough coverage of the site. (cameras, sensors, security guards) - Weak access control systems.	Network: Low (1) Process: Medium (2) People: Medium (2) Business: Medium (2) 1+2+2+2 = 7 Total: Medium	High Assault/trespassing can cause harm to others on site and could cause asset theft or damages. This may compromise Confidentiality if sensitive data is exposed, weaken Integrity with unauthorised changes, and disrupt Availability by affecting operations.	Medium*High=High	1) Firstly, secure the premise ensuring the assaulter/trespasser has no escape. 2) Dispatch security guards informing them about the situation. 3) Review the area ensuring that the unauthorised user has been delt with.	Procedural: Regularly update physical security policies and provide ongoing staff training to reinforce security awareness and response procedures. Technical: Install and actively monitor CCTV and alarm systems to ensure comprehensive surveillance. Physical: implementing biometric systems and keycard	Medium	- Implement more detective security devices on site (alarms, cameras and sensor) all of which can help identify any unauthorised users. - Carry out both security drills and regular maintenance of surveillance equipment. - Hire more security guards on campus making sure all vital areas have coverage.

								access, to restrict entry to authorised users.		
--	--	--	--	--	--	--	--	--	--	--

5.1 Controls:

These controls are required implementations to prevent and minimise the consequences of the risks.

Control – Measures to prevent risks impact.

Type of Control – controls are either (prevent, detect, correct, compensate), and it is then categorised (technical, procedural, physical)

Implementation – How the control will be put into action and deployed

Estimated Cost – Ruff idea of how much it would cost

Industry References - references to industry frameworks

Control	Type of Control	Implementation	Estimated cost	Industry References
Multi factor authentication (Hong**, 2011)	Preventive Technical	- Integrate MFA through mobile authentication apps, email, SMS, or hardware tokens. By implementing MFA, it creates several layers of protection, making it difficult for attackers to brute force their way through systems. - Stages for Implementation: Firstly, integrate it through training, then integration testing, and lastly use risk-based adaptive authentication to ensure everything works effectively and smoothly within IT systems.	Free to £60,000 yearly	NIST SP 800-63B, CIS Controls, ISO 27001
Encryption (M.Davis, 1978)	Preventive Technical	Use strong encryption techniques, e.g. AES-256, to protect data at both rest and in transmission. This protects sensitive information against unauthorised access and maintains its confidentiality and integrity. Make sure to properly incorporate the encryption components to find a balance between both security and performance, consider optimising hardware and staying current with future technological improvements.	£20,000 to £50,000 yearly	NIST guidelines, ISO 27001, CIS Controls
System monitoring (Muhammad Sheeraz1, 2023)	Detective Technical	Utilise monitoring tools (SIEM) to gather logs from network devices, servers, and user devices. Live dashboards and automated alerts for a continuous monitoring of every operation carried out. Also, consider both on-premises and cloud solutions to identify the best fit in terms of cost and growth potential.	£25,000 to £75,000 yearly	NIST, CIS Controls
Protective software tools (eg. firewall, antivirus) (Yuan, 2016)	Preventive Technical	Implement next-generation security solutions (antiviruses, firewalls, anti-malware tools) to aid in the detection and mitigation of potential malicious threats. To decrease operational expenses, conduct frequent vulnerability assessments and incorporate solutions into current endpoint management. Note: To maximise effectiveness, make sure to regularly update tools to keep up with mitigating newer threats.	£15,000 to £30,000 yearly	CIS Controls, ISO 27001

Vulnerability Scanning (Penetration testing) (Bishop, 2007)	Detective Procedural	Schedule regular vulnerability scans and penetration tests to identify and address weak points within systems, allowing quick action to prevent possible system exploitation. Combine both internal assessments and third-party audits and focus on fixing critical issues first. This ensures that the company can keep improving defences over time.	£10,000 to £20,000 yearly	NIST, CIS Controls, ISO 27001
Patch Management Policy (Hassani, 2020)	Preventive Procedural	Implement an automated scheduled patch management system with clear service level agreements. Test patches in a controlled environment, specifically on a critical system, for smooth operations. This maintains system integrity and helps minimise system downtime.	£10,000 Initial	NIST, CIS Controls
Role based access control (RBAC) (Sandhu, 1998)	Preventive Procedural	RBAC is important for making sure that only certain staff have access to certain information depending on what operations they carry out, which determines their access privileges. This reduces the chances of accidental or intentional infections	£10,000 to £30,000 Initial	ISO 27001, NIST
Regular system backups and recovery (O'Reilly, 2006)	Corrective Procedural	Having automated scheduled backup for both on-site and off-site (cloud) storage creation can ensure that a company's data is copied and stored securely. This provides quick restoration of lost data, if data was to be tampered with or damaged. Note: Backups must be regularly tested to confirm that they function properly, as damaged backups can lead to unsuccessful data recovery.	£10,000 to £20,000 yearly	NIST, ISO 27001, CIS Controls
Network Segmentation (Neerja Mhaskar, 2021)	Preventive Technical	The process of dividing a network into smaller, isolated segments, which helps restrict the propagation of malware. In the case that one segment becomes infected, other areas of the network will remain secured, minimising the propagation of the attack. Configuring (VLANs, setting strict access controls, setting up firewalls, and pen tests) prevents any lateral movement.	£25,000 to £50,000 Initial	NIST SP 800-115, CIS Controls, ISO 27001
Physical security enhancements	Preventive Physical	Physical security implementations: - Biometric or keycards scanners to prevent unauthorised access to sensitive rooms. - Cameras for surveillance and quick incident responses.	£50,000 to £100,000 Initial	ISO 27001, CIS Controls

		- Implement alarms and sensors to detect and notify unauthorised trespassing or theft of assets. - Onsite security guards for continuous monitoring. - Port blockers to prevent the connection of unauthorised access medias (USB). These practices will strengthen these measures, creating a more secure environment.		
Staff Training Security Awareness (Caldwell, 2016)	Preventive Procedural	Deliver regular training programs ensuring staff are up to date with the knowledge of attacks (phishing emails, malicious downloads, links, social engineering tactics, and new emerging threats). This training can develop skills to easily identify any suspicious activities, reducing the spread of attacks, as staff with training are less likely to interact with these malicious attack attempts. - Training could include scenario-based training in which employees are tested to identify possible threats through examples threats (e.g. phishing emails).	£5,000 to £10,000 yearly	NIST, CIS Controls, ISO 27001
Incident Response plan (Charles DeVoe, 2013)	Corrective Procedural	Create an incident response plan detailing roles, communication channels, and the recovery steps. - Ensure that these plans are regularly tested through drills to make sure all members are prepared beforehand for rapid isolation of affected systems, stakeholder communication, and regulatory compliance.	£5,000 to £10,000 yearly	NIST SP 800-61, ISO 27001
Intrusion Detection Systems (Biermann, 2001)	Detective Technical	IDS allows the monitoring of network traffic and detect any malicious activities. Integrate SIEM for consolidated alerting and regularly adjust the detection to minimise false positives while remaining up to date on evolving threats.	£20,000 to £40,000 initial	NIST, CIS Controls
Emergency Power Supply	Compensatory Physical	- Implement backup generators and UPS systems to have continuous power for any important services.	£100,000 to £200,000 Initial	ISO 27001, NIST

		- Regular maintenance to check supplies are ready to use in case of unexpected outages. - Access risk to work out the redundancy measures.		
Secure Wi-Fi Networks (Hole, 2005)	Preventive Technical	Should utilise Wi-Fi networks that are encrypted (WPA3), ensuring that access is limited to authorised devices and personnel only. Should also regularly update passwords to prevent unauthorised access and set up a separate guest network for visitors. Monitoring network activity for unusual behaviour, ensuring robust firewall protection. Additionally, educating staff on safe Wi-Fi practices will help secure sensitive data.	£20,000 to £40,000 Initial	CIS Controls, NIST, ISO 27001
Password Policies (SHAY, 2016)	Preventive Procedural	Implement password policies making it difficult for attackers to work out passwords of users. It can contain the following - Must contain (numbers and symbols). - Regular password changing (every 3 months and no reuse of old passwords). - Passwords must contain a minimum number of characters. - Restrict password sharing. - Passwords should avoid using common phrases from the dictionary. - System lockout to prevent multiple invalid attempts of access.	£1,000 to £5,000 yearly	NIST, CIS Controls
Physical Access Controls (Fennelly, 2017)	Preventive Physical	Install biometric or keycard scanners to restrict any unauthorised physical access to sites. Ensures entry to sensitive areas is controlled using integrated surveillance, alarm and sensors systems for enhanced protection.	£30,000 to £60,000 Initial	ISO 27001, CIS Controls

6 Evaluation and Discussion:

The WannaCry attack was a groundbreaking event in cybersecurity, which highlighted to the public how the lack of simple cybersecurity measures (outdated technology/software and the underinvestment within IT) can lead to significant consequences.

The attack exploited the EternalBlue vulnerability, which was only found within outdated Windows systems. This allowed WannaCry to impact many companies, especially the NHS, which led to many issues in the health department, ranging from cancellations of appointments, the diversion of emergency services, and financial loss. Additionally, this attack highlighted to companies the importance of security, as this incident could have been prevented if a well-structured ISMS had been implemented. This evaluation will explore the long-term policy implications for the NHS and provide a cost-benefit analysis for the NHS.

A conclusion that was identified by the WannaCry incident is the necessity to implement a proactive security framework. This ISMS would have developed an organised approach to help identify and address the vulnerabilities. The mitigation strategies that were discussed within the control section of this report suggest adding features such as patch management policy, network segmentation, and system monitoring would have identified the main weakness of WannaCry. Patch management is crucial, as keeping software up to date and automating the rollout of important patches can help NHS fix known vulnerabilities before they can be exploited.

Implementing network segmentation would have minimised the spread by keeping critical systems isolated. This way, if malware were to infect a system, it would not have been able to propagate as rapidly as usual. Additionally, implementing regularly scheduled system backups. Would have ensured that businesses can keep running and maintain data integrity even if they do face a successful attack, as compromised data can be recovered using system backups, minimising both recovery costs and system downtime.

If this ISMS had been in place during WannaCry, it would have had a well-structured framework for proactive risk management. An effective ISMS that conducts ongoing risk assessments would have helped with identifying the vulnerability. EternalBlue and implemented patch applications, its policies on network segmentation and response planning, which were discussed within the risk register, would have strengthened the NHS's defences. While other controls like staff training would have minimised, the impact caused by breaches. This approach, part of an ISMS, would have prevented the attacks spread by making cybersecurity a core practice.

WannaCry was a wake-up call as it changed the way in which public policies and cybersecurity investments were dealt with. This incident triggered a major revision of cybersecurity procedures, as this led to a greater amount of funding within IT systems, a stronger focus on more modern security measures, and the integration of trusted frameworks like the NIST. This

secures sensitive patient data and allows healthcare to provide continuity by the implementation of stronger cybersecurity.

It is essential to also consider the cost benefits of implementing the suggested controls. In the case of WannaCry, the financial loss combined with the disruptions to essential services highlights the cost-effectiveness of investing in stronger security measures than the recovery costs, as recovery of systems was too costly.

This cost benefit also explains why many organisations (NHS) were not able to implement these controls, mainly being the budget restraints and other company priorities, which delayed the investment for a stronger security. However, the event of WannaCry highlights that the cost of the attack outweighs the expenses for implementing these controls. Furthermore, standards have evolved in the present day, as now, rather than cybersecurity being an optional investment, it is now a crucial role in keeping operations resilient and protecting assets.

In conclusion, WannaCry exploited many weaknesses within the cybersecurity posture of the NHS. The highlighted controls of patch management, network segmentation, scheduled backups, and system monitoring, along with integrating the ISMS, aim to prevent rather than just react to the threats. Had this ISMS been in place, it would have successfully identified and mitigated the vulnerabilities that were exploited. Ensured rapid incident response and improvements with cybersecurity along with a clear cost-benefit analysis; these measures highlight the economic and operational imperatives for investing in cybersecurity.

Bibliography

- Adam B. Turner, S. M. a. A. J. U., 2024. A target-centric intelligence approach to WannaCry 2.0. 29 12, pp. 1 - 20.
- Aljaidi, M., 2024. NHS WannaCry ransomware attack: Technical explanation of the vulnerability, exploitation, and countermeasures. 21 12, p. 3.
- Anon., 2003. *Assets in action*, s.l.: s.n.
- Anon., 2018. Data Security Standards. pp. 2-18.
- Anon., 2024. A retrospective impact analysis of the WannaCry cyberattack on the NHS. 29 12, pp. 1 - 7.
- Anon., 2024. Investigation: WannaCry cyber attack and the NHS. 22 12, p. 21.
- Anon., 2024. Lessons learned review of the WannaCry Ransomware Cyber Attack. 22 12, p. 34.
- Anon., n.d. *Massive ransomware infection hits computers in 99 countries*. [Online]
Available at: <https://www.bbc.co.uk/news/technology-39901382>
[Accessed 20 12 2024].
- Anon., n.d. *NHS England business continuity management toolkit case study: WannaCry attack*. [Online]
Available at: <https://www.england.nhs.uk/long-read/case-study-wannacry-attack/>
[Accessed 20 12 2024].
- Anon., n.d. *NHS seeks to recover from global cyber-attack as security concerns resurface*. [Online]
Available at: <https://www.theguardian.com/society/2017/may/12/hospitals-across-england-hit-by-large-scale-cyber-attack#:~:text=Lorina%20Nash%2C%2046%2C%20from%20Hertfordshire,accident%20and%20emergency%20so%20empty.>
[Accessed 04 01 2025].
- Anon., n.d. *Pharmacy technician*. [Online]
Available at: <https://www.healthcareers.nhs.uk/explore-roles/pharmacy/roles-pharmacy/pharmacy-technician>
- Anon., n.d. Role-based Access Control.
- Biermann, E., 2001. A comparison of Intrusion Detection systems. 12.
- Bishop, M., 2007. About Penetration Testing.
- Brenner, J., 2007. *ISO 27001 risk management and compliance..* s.l.:s.n.
- Caldwell, T., 2016. Making security awareness training work. 06.
-

Charles DeVoe, S. (. M. R., 2013. INCIDENT RESPONSE PLAN FOR A SMALL TO MEDIUM SIZED HOSPITAL.

Chen, Q., 2017. A Case Study of WannaCry Ransomware. *Automated Behavioral Analysis of Malware*, p. 2.

Fennelly, L. J., 2017. *Effective Physical Security*. s.l.:s.n.

Gazet, A., 2024. Comparative analysis of various ransomware virii. 21 12, p. 1.

Groš, S., 2021. A Critical View on CIS Controls.

Hassani, P., 2020. Implementing Patch Management Process. 05.

Hole, K. J., 2005. Securing Wi-Fi Networks.

Hong**, J.-J. K. a. S.-P., 2011. A Method of Risk Assessment for Multi-Factor Authentication. 03, pp. 1-12.

Karen A. Scarfone, 2008. SP 800-115. Technical Guide to Information Security Testing and Assessment.

Liu, Z., 2024. Working mechanism of Eternalblue and its application in ransomware. 28 12, pp. 1 - 23.

M.Davis, R., 1978. The Data Encryption Standard in Perspective. 10, pp. 1-5.

Maxat Akbanov, V. G. V. a. M. D. L., 2024. WannaCry Ransomware: Analysis of Infection, Persistence, Recovery Prevention and Propagation Mechanisms. 26 12, pp. 1 - 12.

Milan Tuba, S. A. A. J., 2024. ICT Systems and Sustainability. 30 12, p. 742.

Muhammad Sheeraz1, M. A. P., 2023. Human-centric Computing and Information Science. 04, pp. 1-19.

Neerja Mhaskar, M. A. R. K., 2021. A Formal Approach to Network Segmentation. 04.

NHS, 2003. Assets in action.

O'Reilly, 2006. Backup & Recovery. 01 12.

Peter Mell, T. G., 2011. The NIST Definition of Cloud. p. 09.

S. Ghafur, S. K. K. H. G. M. A. D. P., 2024. A retrospective impact analysis of the WannaCry cyberattack. 30 12, pp. 1-7.

Sailio, M., 2020. Cyber Threat Actors for the Factory of the Future. 04 30 .

Sandhu, R. S., 1998. Role-based Access Control.

SHAY, R., 2016. Designing Password Policies for Strength and Usability. 05.

Tarah Wheeler & John, L. A., 2024. Cyber Collateral: WannaCry & the impact of cyberattacks on the mental health of critical infrastructure defenders. 22 12, p. 7.

Yuan, E., 2016. Architecture-based self-protecting software systems. pp. 1-180.